



Branding7

Revisão completa

4 de outubro de 2026

versão zzz44

Sistema B7

revisão geral

Auditoria de código, segurança e interface do sistema inteiro — o que foi encontrado, o que já foi corrigido e o que ainda precisa de decisão sua.

42.140

linhas de JavaScript

67

tabelas no banco

17

telas revisadas

21

achados

11

já corrigidos

O essencial em uma página

Revisei o sistema inteiro: todo o JavaScript, as 88 migrações do banco, as funções de servidor e as 17 telas abertas num navegador de verdade. Foram **21 achados**. **Onze já estão corrigidos** neste mesmo pacote. Um exige decisão sua, e é o mais sério.

2 graves (1 corrigido)	8 médios (7 corrigidos)	11 leves (3 corrigidos)	0 telas com erro de JavaScript
-------------------------------------	--------------------------------------	--------------------------------------	---

⚠ Precisa da sua decisão: designers e videomakers podem apagar dados de qualquer cliente

Uma migração de 30 de setembro afrouxou as permissões do banco sem querer. Hoje, quem tem conta de **designer** ou **videomaker** consegue alterar ou apagar clientes, linhas editoriais, conteúdos, roteiros e gravações de **qualquer cliente** — não pelo sistema, que trava na tela, mas chamando a API direto.

Deixei a correção pronta em `migration_rls_corte_3.sql`. **Não rodei no banco** porque ela muda o acesso da sua equipe e eu preferi que você soubesse antes. Detalhes na página 7.

O que já está corrigido

CORREÇÃO	ONDE APARECIA	GRAVIDADE
Duplicar semana jogava as demandas para fora da semana	Status semanal	ALTO
Seletor de roteiro mostrava só 5 e sem a gravação	Gravações	MÉDIO
Botão agia na versão errada em conexão lenta	Produção de vídeo	MÉDIO
"Assumir demanda" não mudava nada na tela	Design	MÉDIO
Progresso e contadores ficavam parados	Design	MÉDIO
"Visualizar como..." sumia sem internet	Sistema todo	MÉDIO
Duplicar dezembro criava janeiro do ano errado	Linha editorial	MÉDIO
Gravação de hoje sumia à noite	Portal do cliente	MÉDIO
"Voltar ao Design" não mudava o endereço	Design	MÉDIO
Proteção contra injeção reforçada	Sistema todo	BAIXO
Vazamento de memória ao abrir o perfil	Meu perfil	BAIXO

Como revisei. Quatro frentes em paralelo: o núcleo (rotas, sessão, banco, service worker), as telas grandes (Design, Vídeo, Painel, Kanban), as telas de conteúdo (linha editorial, semanas, calendário, portal) e a segurança (segredos, permissões do banco, funções de servidor, injeção). Cada achado foi conferido no

O que é o Sistema B7

Um aplicativo web que acompanha o conteúdo da Branding7 do planejamento à entrega: a linha editorial do mês, a gravação, a edição do vídeo, a arte do design, a aprovação do cliente e o status semanal que vai para ele.

O caminho do conteúdo

1 Linha editorial O planejamento do mês de cada cliente: pilares, conteúdos, datas.	2 Gravação Roteiros, cenas e a sessão marcada no calendário.	3 Produção Vídeo e Design puxam as demandas da linha e tocam em kanban.	4 Aprovação O cliente vê, comenta e aprova pelo portal dele.	5 Status semanal O relatório de sete dias que vai para o cliente.
---	--	---	--	---

Como foi construído

Sem framework, de propósito

HTML, CSS e JavaScript puros. Nenhuma etapa de compilação: o que está no repositório é exatamente o que roda no navegador. Publicar é dar um merge — o GitHub Pages serve os arquivos em menos de um minuto.

Supabase como banco

67 tabelas em PostgreSQL. A segurança mora no banco (políticas por linha), não na tela — esconder um botão não protege nada. Sete funções de servidor cuidam de login, IA, notificações e agenda.

Aplicativo instalável

Funciona como app no celular, com ícone na tela inicial, notificações e um cache próprio que deixa o sistema abrir na hora e continuar de pé sem internet.

Cinco papéis

Administrador, coordenador, designer, videomaker e cliente. Cada um enxerga um sistema diferente — o cliente nem chega perto da operação da agência.

Em números

42.140

linhas de JavaScript
em 55 arquivos

14.964

linhas de CSS
em 22 arquivos

88

migrações do banco
18.684 linhas de SQL

156

relatórios de
mudança escritos

O sistema no celular

As 17 telas principais, abertas num navegador de verdade com dados de exemplo. Todas carregaram sem nenhum erro de JavaScript.



Central B7
O panorama do dia



Produção de vídeo
Fila, prazos e kanban



Design
Artes por etapa



Status semanal
O relatório do cliente



Clientes
A carteira da agência



Linhas editoriais
O planejamento do mês



Gravações
Sessões e roteiros



Calendário
Agenda integrada

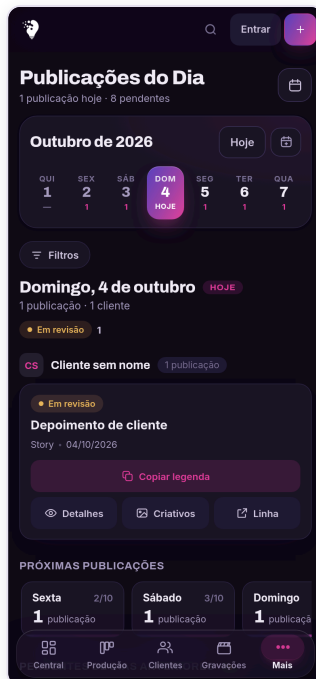
Mais telas



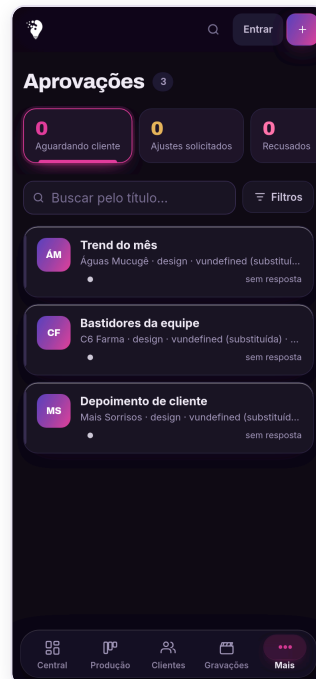
Ficha do cliente
Tudo de um cliente



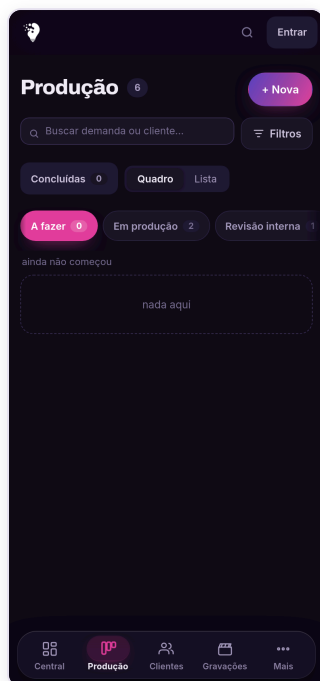
Roteiros
Texto e cenas



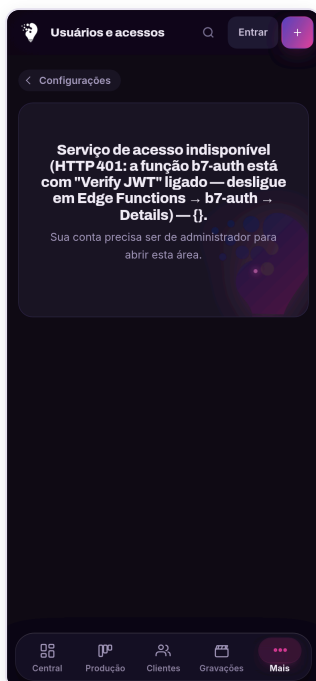
Publicações do dia
O que sai hoje



Aprovações
O aval do cliente



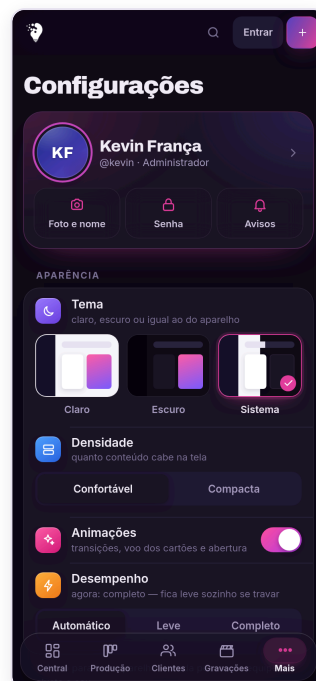
Kanban
Quadro de demandas



Usuários
Contas e acessos

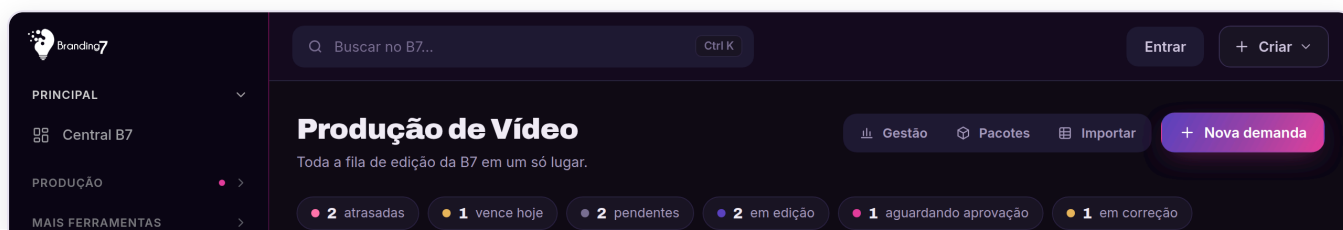


Meu perfil
Foto, senha, avisos



Configurações
Aparência e sistema

No computador



O que foi corrigido

Cada item abaixo foi conferido no código antes de virar correção. Todos já estão neste pacote e passaram pelos testes automáticos.

Duplicar uma semana jogava as demandas para fora dela

ALTO

CORRIGIDO

No Status semanal, "Duplicar para outra semana" deixa você escolher qualquer data — mas as demandas andavam **sempre sete dias**, não importa a semana escolhida.

Na prática: duplicar a semana de 05/10 para 26/10 criava a semana certa, mas com as demandas datadas em 12/10 — fora do intervalo. Elas caíam no balde "sem data" do editor. Em silêncio, no meio do fluxo principal de planejamento.

`js/semana.js` · agora o deslocamento é a distância real entre as duas semanas.

O seletor de roteiro mostrava só 5 e sem a gravação

MÉDIO

CORRIGIDO

Havia **duas funções com o mesmo nome** no arquivo do banco. Em JavaScript a última vence, então a primeira virou código morto — e quem chamava do jeito antigo recebia outra coisa.

Na prática: em Gravações → "Adicionar item" → "Roteiro existente", apareciam apenas 5 roteiros (antes: até 200), o agrupamento por mês ficava sempre vazio e o subtítulo de cada roteiro saía em branco.

`js/database.js` · `js/gravacao.js` — função duplicada removida.

Em conexão lenta, o botão agia na versão errada do vídeo

MÉDIO

CORRIGIDO

Ao abrir uma demanda e trocar para outra antes de carregar, a resposta atrasada da primeira sobrescrevia a lista de versões — depois de a tela da segunda já estar desenhada.

Na prática: a tela mostrava a demanda B, mas "enviar para aprovação" e "registrar entrega" agiam na versão da demanda A. Escrita no lugar errado, sem aviso nenhum.

`js/video.js` · o estado só é gravado se a tela ainda for a mesma.

"Assumir demanda" não mudava nada na tela

MÉDIO

CORRIGIDO

Na prática: o designer clicava em "Assumir demanda (4)", via o aviso "4 demandas assumidas" — e o botão continuava dizendo "Assumir demanda (4)", com as peças ainda sem responsável. Clicando de novo: "Nenhuma demanda sobrou". Parecia que tinha falhado. Só recarregando a página resolvia.

`js/design.js` · a ação recarregava uma lista e a tela desenhava a partir de outra.

Progresso e contadores ficavam parados no Design

MÉDIO

CORRIGIDO

Na prática: aprovar uma peça pela gaveta lateral atualizava a gaveta, mas atrás dela o percentual ("3 de 11 finalizadas"), a barra de progresso e os contadores das abas continuavam no valor antigo. Mesma coisa ao trocar responsável ou prazo.

`js/design.js` · mesma causa do anterior: duas listas que não conversavam.

Corrigidos (continuação)

"Visualizar como..." sumia sem internet

MÉDIO

CORRIGIDO

Na prática: um dos arquivos do sistema ficou de fora da lista do cache. Abrindo o app instalado sem rede, o recurso de ver o sistema pelos olhos de outro papel simplesmente desaparecia, sem erro e sem explicação.

`sw.js` · arquivo incluído na lista.

Duplicar a linha de dezembro criava janeiro do ano errado

MÉDIO

CORRIGIDO

Na prática: o mês já vinha sugerido como janeiro, mas o ano continuava preso em 2026. Clicando direto em "Duplicar", nascia uma linha "janeiro 2026" — onze meses no passado. Exatamente na virada do ano.

`js/linha.js`

A gravação de hoje sumia do portal à noite

MÉDIO

CORRIGIDO

Na prática: o portal do cliente calculava "hoje" no fuso de Londres. A partir das 21h no Brasil, a data já tinha virado lá — e a gravação marcada para hoje desaparecia da tela do cliente três horas antes da meia-noite.

`js/portal.js` · passou a usar a data local, como o resto do sistema.

"Voltar ao Design" não mudava o endereço

MÉDIO

CORRIGIDO

Na prática: voltar para a fila, filtrar e recarregar levava de volta para a página da linha. O mesmo endereço virava duas telas diferentes, e compartilhar o link mandava a pessoa para o lugar errado.

`js/design.js`

Proteção contra injeção reforçada

BAIXO

CORRIGIDO

A função que neutraliza texto vindo do banco não tratava a aspa simples. Hoje nada é explorável — todo atributo do sistema usa aspa dupla —, mas bastava um atributo novo escrito com aspa simples para abrir a porta. Fechada antes de alguém abrir.

`js/ui.js`

Vazamento de memória ao abrir "Meu perfil"

BAIXO

CORRIGIDO

Cada abertura do perfil deixava para trás um observador de tamanho de janela preso a uma tela já descartada. Não quebrava nada, só acumulava trabalho inútil em sessões longas.

`js/perfil.js`

Segurança

A varredura de segredos e de permissões não encontrou nenhum vazamento — mas encontrou uma porta aberta no banco.

⚠ Designers e videomakers podem apagar dados de qualquer cliente

A migração `migration_rls_corte_2.sql`, de 30 de setembro, trocou a regra de escrita de 18 tabelas. Antes, escrever era coisa de **administrador e coordenador**; o designer tinha leitura e nada mais — está escrito assim, com todas as letras, nas migrações anteriores e num comentário do próprio código.

Depois do corte, a regra passou a valer para **toda a equipe interna** — incluindo designer e videomaker — e para **todas as operações**, não só leitura.

O que isso permite: uma conta de designer ou videomaker pode alterar ou apagar clientes, linhas editoriais, conteúdos, roteiros, gravações e status semanais de qualquer cliente. Pelo sistema não dá — a tela trava. Chamando a API direto, dá.

A correção está pronta

Escrevi a migração que devolve o desenho original, mas **não rodei no banco**: ela muda o acesso da sua equipe e isso é decisão sua, não minha.

O que a migração faz

- **Escrever** (criar, alterar, apagar) nas 17 tabelas editoriais volta a ser só de administrador e coordenador.
- **Ler** continua liberado para toda a equipe interna — designer e videomaker seguem vendo o briefing, como hoje.
- **Registro de atividades** é a exceção: designer e videomaker continuam podendo registrar o que fizeram, mas não apagar o registro.
- Ela também resolve uma ambiguidade antiga: a função que define "equipe interna" tinha duas versões diferentes, e qual valia dependia da ordem em que as migrações foram aplicadas.

```
-- SQL Editor do Supabase · migration_rls_corte_3.sql
-- seguro rodar mais de uma vez; a conferência está no fim do arquivo
```

Antes de rodar, vale confirmar comigo: alguém da sua equipe com conta de designer ou videomaker precisa *editar* linha editorial, conteúdo, roteiro ou gravação pelo sistema hoje? Se precisar, eu ajusto a migração para liberar exatamente aquilo, em vez de liberar tudo.

O que está correto

O resto da varredura não encontrou problema: estes pontos foram conferidos um a um.

Nenhum segredo vazado

Varri o código, as migrações, os arquivos de build e os 164 commits do histórico. A única chave presente é a pública, que deve mesmo estar lá. Nenhuma senha, token de IA ou chave de administrador do banco.

Proteção por linha em todas as tabelas

Todas as 67 tabelas têm a proteção ligada. Um cliente só alcança os dados dele, e só o que foi liberado. A chave pública, sozinha, não alcança tabela nenhuma.

Login bem feito

O papel sempre vem do banco, nunca do navegador. Mensagem de erro única (não revela se a conta existe), limite de tentativas, comparação de senha em tempo constante e trava para não apagar o último administrador.

Texto do banco é neutralizado

Cerca de 1.800 usos da função de escape, e nenhum caso de texto do banco entrando cru na tela. Links externos passam por uma peneira que só aceita endereços de verdade.

Achados leves, registrados

O QUÊ

EFEITO

Zoom do roteiro é salvo e nunca lido

Perde-se a cada recarga

Duplicar demanda repete a posição

Ordem do dia fica a cargo do banco

Busca de roteiros concatena texto vazio

Buscar "und" traz roteiros incompletos

Aba "Equipe" não limpa o bloco de cima

Chips ficam sobre a grade de designers

Dica da barra lateral recolhida nunca ligada

Ícones sem rótulo ao recolher

Atalho "Nova demanda" procura o botão por 8s

Pode abrir sozinho ao voltar à tela

Limpezas de tela acumulam por redesenho

Desperdício, sem efeito visível

O que deixei em aberto

Estes achados são reais, mas mudam comportamento do produto ou pedem uma decisão — não quis decidir por você. Nenhum deles quebra nada hoje.

Conteúdo de hoje já nasce "Publicado" pela manhã

MÉDIO

DECISÃO SUA

Ao abrir a Linha Editorial, todo conteúdo "Programado" com data **até hoje** vira "Publicado" automaticamente — e isso é gravado no banco.

Na prática: às 8h da manhã você abre a linha do dia e os conteúdos marcados para hoje às 18h já aparecem como publicados. O resto do sistema usa a regra oposta ("antes de hoje"), então as duas pontas discordam.

A decisão: o conteúdo de hoje deve virar publicado só amanhã (coerente com o resto), ou a regra atual é proposital?

"Copiar datas de postagem" copia o mês errado

MÉDIO

DECISÃO SUA

Na prática: duplicar a linha de outubro para novembro com "Datas de postagem" marcado cria a linha de novembro com todos os conteúdos datados em outubro. É opcional e fica visível, mas gera dado errado em lote.

A decisão: as datas devem andar um mês junto com a linha (o que parece ser a intenção), ou a opção serve mesmo para copiar as datas literais?

Cada toque na tela copia a tela inteira

BAIXO

DECISÃO SUA

O recurso que guarda uma "foto" da tela para a transição entre telas roda em **todo clique**, não só nos que navegam. Numa lista com dezenas de cartões no celular, cada toque serializa a tela inteira antes do clique chegar ao destino.

Deixei como está porque mexer aqui afeta a animação de troca de tela — e você pediu para voltar as animações como estavam. Se o toque parecer lento em listas grandes, é o primeiro lugar para olhar.

Função de sincronizar sem autenticação

BAIXO

DECISÃO SUA

A função de servidor que busca datas comemorativas aceita uma chamada sem nenhum login. Há uma trava de 30 minutos entre execuções, então o risco é gasto de recurso, não dado errado.

Como está a saúde do sistema

O que está bem feito

- **Disciplina com datas.** Existem funções próprias para trabalhar com dias e semanas, e elas acertam a virada de mês e de ano. Os desvios encontrados foram exceções.
- **Segurança no banco, não na tela.** O princípio está certo e aplicado: esconder botão não é proteção.
- **Teste automático a cada envio.** Abre as 19 telas num navegador real e falha se alguma quebrar. Foi ele que me deu confiança para corrigir onze coisas de uma vez.
- **O código se explica.** Os comentários dizem por que a decisão foi tomada, não o que a linha faz. Isso é raro e vale muito.
- **Histórico escrito.** 156 relatórios de mudança — dá para reconstruir o raciocínio de qualquer decisão.

Onde está o risco

- **As permissões do banco.** É o único achado que expõe dado de verdade, e já tem correção escrita esperando sua decisão.
- **Arquivos muito grandes.** Design tem 3.719 linhas e Vídeo, 2.991. Foi exatamente neles que apareceram os bugs de "duas listas que não conversam".
- **Estado que sobrevive à troca de tela.** A causa de dois achados. Algumas telas se protegem disso, outras não — vale padronizar.
- **Testes só de fumaça.** Eles garantem que a tela abre, não que a conta está certa. O bug de duplicar semana passaria batido por eles.

O que eu faria em seguida

ORDEM	O QUÊ	POR QUÊ
1	Decidir e rodar a migração de permissões	É o único risco real de dado
2	Responder às duas decisões de produto	Dado errado em silêncio
3	Testar as contas de cálculo	Datas, semanas e duplicações
4	Quebrar Design e Vídeo em partes	Onde os bugs se escondem

Resumo honesto. O sistema está em boa forma para o tamanho que tem. Nenhuma tela quebra, nenhum segredo vazou e os princípios de segurança estão certos. Os bugs que encontrei são do tipo que só aparece com uso real — dado errado em silêncio, tela que não atualiza, data que escorrega — e não do tipo que derruba o sistema. A exceção é a permissão do banco, que está aberta desde 30 de setembro e merece sua decisão ainda esta semana.

